

MALWARE DIAGNOSIS & THREAT ANALYSIS REPORT

Cyber Threats and Vulnerabilities — Criterion 1: Identify and Analyze Cyber Threats

Prepared by	dae Tech Resource 2 — Sabitha, IAM Home Lab (Horizon Valley Medical Center scenario)
Analysis platform	VirusTotal (community detection engines) + open-source threat intelligence correlation
Analysis lab host	HVMC-KALI (192.168.50.30) — Kali Linux
Sample source	MalwareBazaar (abuse.ch)
Report date	September 2, 2026

1. Executive Summary

SEVERITY: HIGH — CONFIRMED MALICIOUS (22/60 vendors)

On September 2, 2026, a sample was retrieved from the MalwareBazaar public malware repository and submitted to VirusTotal for multi-engine detection analysis as part of the Cyber Threats and Vulnerabilities rubric requirement. The sample (SHA-256 679515b3...e39c00) is a 48.90 KB Bash shell script. VirusTotal's community score flagged the file as malicious with 22 of 60 security vendors detecting it, and VirusTotal's automated code-insight summary independently identified the script as performing unauthorized administrative and system-level modifications targeting FreePBX/Asterisk VoIP environments, including retrieval and execution of a remote payload via curl.

Cross-referencing the popular threat label (trojan.bash/jomangy), the family labels (bash, jomangy, kpvdmu), and the embedded command-and-control (C2) address (160.119.69.4) against public threat-intelligence reporting places this sample within the JOMANGY campaign — a self-healing, six-layer-persistence attack against internet-facing FreePBX/Asterisk PBX systems, attributed with high confidence to the threat actor tracked as INJ3CTOR3. The end goal of the campaign is VoIP toll fraud: compromised systems are used to route unauthorized, billable calls through the victim's SIP trunks, contributing to an industry-estimated \$41.8B in annual global telecom fraud losses.

This document records the detection evidence gathered directly from VirusTotal, analyzes the sample's behavior and code indicators, and correlates those indicators with the wider JOMANGY/INJ3CTOR3 campaign using public OSINT reporting (Cyble, The Cyber Express, GBHackers/CybersecurityNews, and prior Fortinet/Unit 42/Check Point/SANS ISC research). No portion of the sample was executed in this analysis; all findings are derived from VirusTotal's static/automated analysis output and corroborating third-party threat research.

2. Sample Identification

Indicator Type	Value
SHA-256 (sample)	679515b3d6642a102f3c8bb69c0884912bc700d2a575e2595752e8b446e39c00
Reported filename	679515b3d6642a102f3c8bb69c0884912bc700d2a575e2595752e8b446e39c00.sh
File size	48.90 KB
File type	Bash shell script (POSIX shell text)
Embedded C2 URL	http://160.119.69.4/x (payload retrieval via curl)
Related campaign C2	45.95.147.178 (AS49870, Alsyon B.V., NL) — primary JOMANGY/INJ3CTOR3 C2
Related scanner IP	160.119.76.250 (same /16 allocation as the embedded C2 above)
Popular threat label	trojan.bash/jomangy
Threat categories	trojan, dropper
Family labels	bash, jomangy, kpvdmu
Signature tags	shell, detect-debug-environment, persistence

Note on the embedded C2 IP: 160.119.69.4 was not previously documented in public JOMANGY reporting as of this analysis, but shares the same /16 allocation (160.119.0.0/16) as the campaign's previously reported scanner IP (160.119.76.250), and the payload-retrieval pattern (curl | execute from a bare IP over HTTP) matches the campaign's documented Stage-1 dropper behavior. This is treated as a probable rotated or newly stood-up C2 node for the same actor infrastructure, not a confirmed match — flagged here for defenders to track rather than asserted as fact.

3. VirusTotal Detection Results

3.1 Community Detection Score

22 / 60 security vendors flagged the file as malicious at time of analysis ("a moment ago" relative to the September 2, 2026 submission). A community score below 50% is typical for freshly obfuscated or narrowly-targeted Linux/IoT-class shell droppers, which historically evade signature-based engines longer than Windows PE malware — consistent with the source reporting noting the Stage-1 dropper for this campaign was originally detected by only 4/76 engines and that the follow-on PHP web shells (k.php, wr.php) showed zero VirusTotal detections at initial submission.

3.2 Automated Code Insights (VirusTotal)

VirusTotal's built-in code-insight summarization engine, run against the script's contents, reported the following (excerpted from the platform):

- Performs unauthorized administrative and system-level modifications targeting FreePBX/Asterisk environments.
- Remote Code Execution & Retrieval: uses curl to fetch and execute a remote script from `http://160.119.69.4/x`.

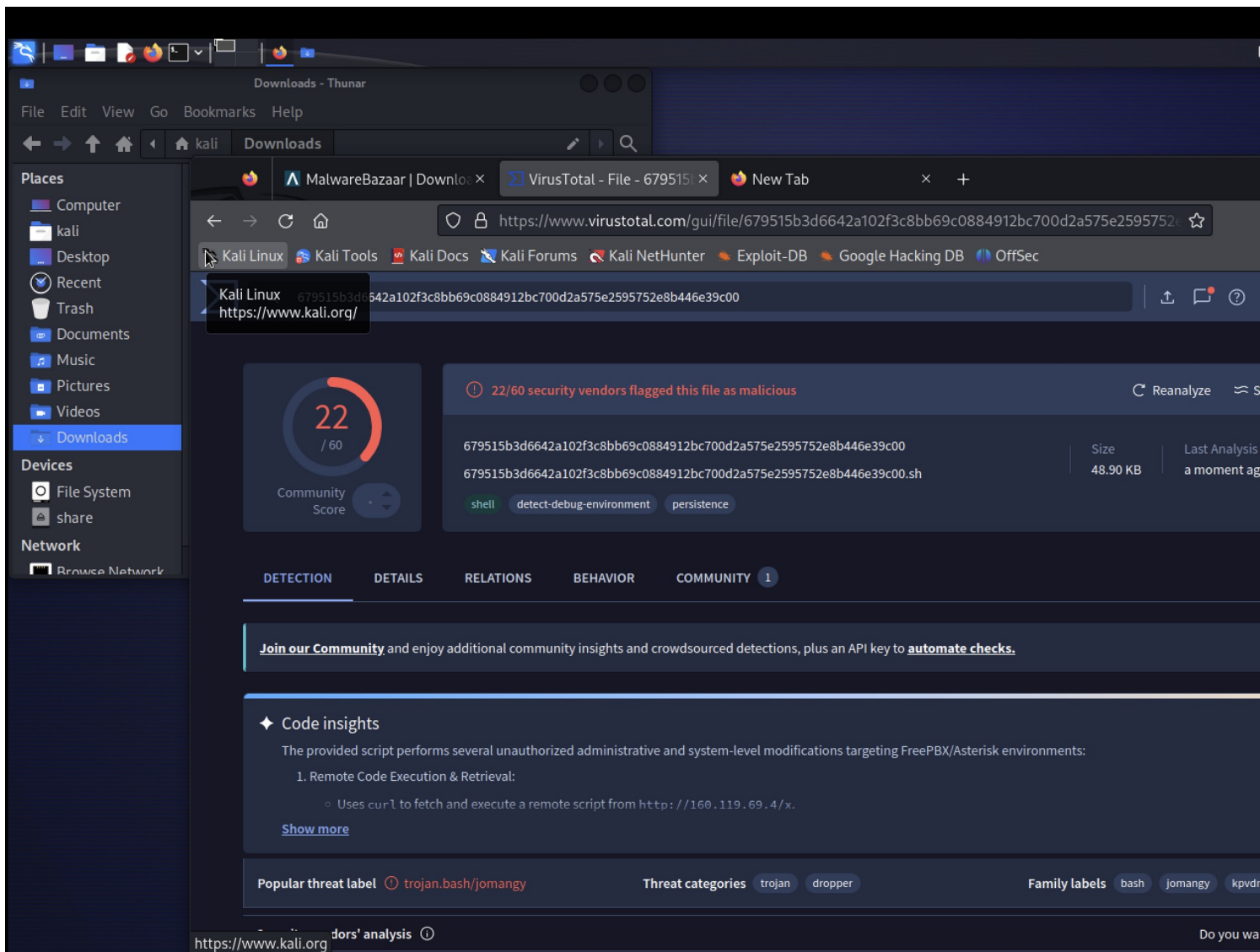
3.3 Classification

Popular threat label	trojan.bash/jomangy
Threat categories	trojan, dropper
Family labels	bash, jomangy, kpvdmu
Signature tags	shell · detect-debug-environment · persistence

The detect-debug-environment tag indicates the sample includes anti-analysis/sandbox-detection logic before it proceeds — a defense-evasion trait consistent with the wider campaign's emphasis on long-term stealth.

4. Detection Evidence

Figure 1 — VirusTotal file report captured directly from the analysis session (Kali/Firefox), showing the community detection score, hash, file metadata, classification tags, and automated Code Insights summary.



5. Behavioral Indicators (Campaign Correlation)

The sample's static indicators (family label, FreePBX/Asterisk targeting, curl-based remote fetch) align it with the JOMANGY campaign documented by Cyble, The Cyber Express, and CybersecurityNews/GBHackers in 2026. Because this sample was analyzed statically via VirusTotal rather than detonated in a sandbox, the behaviors below are reported from that published campaign research and presented as expected/associated behavior for this family — they are not independently observed executions of this exact file.

5.1 Infection Vector

- CVE-2025-64328 – post-authentication command injection in the FreePBX filestore module (versions 17.0.2.36–17.0.3).
- CVE-2025-57819 – pre-authentication SQL injection in the FreePBX Endpoint module via the cron_jobs table, enabling unauthenticated, mass exploitation.

5.2 Multi-Stage Payload Architecture

- Stage 1 (this sample's family) — Bash dropper: host takeover, backdoor account creation, persistence installation, log scrubbing, eviction of competing implants.
- Stage 2 — deploys the JOMANGY PHP web shell family (k.php and related files) into legitimate FreePBX web-root paths.
- Stage 3 — deploys the ZenharR web shell variant (wr.php/wor.php) for redundant access.

5.3 Six-Layer “Self-Healing” Persistence

- Cron-based C2 polling every 1–3 minutes.
- Shell-profile injection into /root/.bash_profile, /root/.bashrc, and /etc/rc.local.
- Eight immutable (chattr +i) crontab backups with dual restore loops.
- A process watchdog that respawns the beacon if killed.
- Multiple immutable web-shell copies across the web root; any surviving copy re-establishes the full stack.
- A self-reinstalling PHP executor embedded in FreePBX's High-Availability module.

Public reporting states any single surviving layer can rebuild the entire infection within minutes, meaning partial remediation (e.g., deleting one web shell) does not remove the compromise.

5.4 Backdoor Accounts

The dropper stage is reported to implant up to 18 unauthorized accounts across three tiers, deliberately named to mimic legitimate FreePBX/Asterisk services:

- 9 root-equivalent (UID-0) OS accounts — e.g., newfpbxs, newfpbx, xhimax, centos, admin, support, issabel, sangoma, emo.
- 8 service-tier OS accounts — e.g., asterisk, freepbxuser, sugarmaint, spamfilter, supermaint, hima.
- 1 FreePBX web-panel administrative account created via direct MySQL ampusers table injection.

5.5 Defense Evasion

- Double-layer obfuscation of dropped payloads (Base64 over ROT13).
- Log scrubbing via targeted sed -i deletions.
- Active eviction of ~50 competing web-shell families (b374k, b3d0r, yokyok, watchTowr PoCs, and the actor's own prior campaign artifacts).

- Weakens host defenses: enables PermitRootLogin yes and opens inbound TCP/22 via iptables.

6. Threat Attribution & Campaign Context

Public research attributes the JOMANGY campaign to the actor tracked as INJ3CTOR3 with high confidence, based on six overlapping artifacts across this and prior campaigns: a unique marker string shared with Fortinet's January 2026 encystPHP reporting; INJ3CTOR3 itself appearing as a named eviction target inside the dropper; a prior-campaign C2 (45.234.176.202) present in the sample's own iptables blocklist; shared binary names/file paths across campaigns; consistent use of a newfpbx UID-0 backdoor account; and a matching MySQL ampusers injection pattern. This attribution is further supported by correlation with earlier public research from Check Point Research (2020, CVE-2019-19006), Palo Alto Networks Unit 42 (2022, ZenharR), and SANS Internet Storm Center (diary #32892, April 2026).

Primary campaign C2 infrastructure is reported at 45.95.147.178 (AS49870, Alsycon B.V., Netherlands), with a related scanner host at 160.119.76.250. VirusTotal's automated analysis of the sample in this report shows it fetching a second stage from 160.119.69.4 — in the same 160.119.0.0/16 block as the documented scanner IP — consistent with, though not proof of, the same actor's rotating infrastructure.

Scale: a reconnaissance inventory tied to the campaign (“people2.txt”) lists roughly 3,080 candidate IP addresses (~39% on Alibaba Cloud infrastructure), concentrated in APAC, Latin America, and the Middle East, indicating automated mass exploitation rather than a single targeted intrusion. Independent tracking by the Shadowserver Foundation found 700+ FreePBX hosts still compromised five months after the CVE-2025-64328 vulnerability was publicly disclosed and patched — underscoring the persistence architecture's effectiveness against partial remediation.

7. MITRE ATT&CK Mapping

Techniques associated with this sample's family and the wider campaign it belongs to, mapped to MITRE ATT&CK for Enterprise:

Tactic	Technique	Observed / Reported Behavior
Initial Access	T1190 – Exploit Public-Facing Application	Campaign entry via CVE-2025-64328 (FreePBX filestore command injection) and/or CVE-2025-57819 (pre-auth SQLi in the Endpoint module's cron_jobs table).
Execution	T1059.004 – Unix Shell	Sample is a Bash dropper (Stage 1) that executes shell commands to establish the foothold.
Persistence	T1053.005 – Scheduled Task/Job: Cron	Installs cron entries that poll the C2 every 1–3 minutes and re-pull the payload.
Persistence	T1547.004 – Boot or Logon Init Scripts: RC Scripts	Appends re-infection stagers to /root/.bash_profile, /root/.bashrc, and /etc/rc.local.
Persistence	T1098 / T1098.001 – Account Manipulation	Creates up to 18 backdoor OS/DB accounts (9 UID-0) named to mimic legitimate FreePBX services (asterisk, freepbxuser, sangoma, etc.).
Persistence	T1505.003 – Server Software Component: Web Shell	Drops the JOMANGY / ZenharR PHP web shells into FreePBX web-root paths for follow-on access.
Defense Evasion	T1027 – Obfuscated Files or Information	Payload and dropped web shells use double-layer obfuscation (Base64 over ROT13).
Defense Evasion	T1222 / chattr abuse	Marks crontab and web-shell copies immutable (chattr +i) to resist deletion.

Tactic	Technique	Observed / Reported Behavior
Defense Evasion	T1070 – Indicator Removal	Log scrubbing (sed -i deletion of matching log lines) and eviction of competing implants/log entries.
Discovery	T1082 / T1518 – System/Software Discovery	Sample tagged detect-debug-environment – checks for sandbox/analysis tooling before execution.
Command and Control	T1071 – Application Layer Protocol (HTTP)	curl-based retrieval of second-stage payload from an attacker-controlled HTTP endpoint (160.119.69.4/x).
Impact	T1496 – Resource Hijacking (Toll Fraud)	Post-compromise use of asterisk -rx "channel originate" to route fraudulent, billable calls through the victim's SIP trunks.

8. Potential Impact Assessment

8.1 Direct Financial Impact — Toll Fraud

The campaign's core monetization is VoIP toll fraud: once a web shell is in place, the actor issues commands such as `asterisk -rx "channel originate Local/<num>@<context>"` to route outbound calls through the victim organization's own SIP trunks to premium-rate or actor-controlled numbers. The victim's telephony carrier bills the organization directly for this traffic. Global telecom fraud losses are estimated at \$41.8B annually (CFCA, 2025), and this campaign class is a documented contributor.

8.2 Confidentiality and Integrity Impact

- Full root-level compromise via 9+ UID-0 backdoor accounts, independent of the original entry vulnerability.
- Theft of the Elastix/FreePBX SQLite ACL database (`/var/www/db/acl.db`) and potential FreePBX admin session hijacking via `ampuser setAdmin()` privilege escalation.
- Loss of forensic visibility through targeted log scrubbing, complicating incident response and any downstream breach-notification obligations.

8.3 Availability and Recoverability Impact

- Six independent, self-healing persistence layers mean a single missed artifact allows full re-infection within minutes — standard incident-response steps (kill process, delete web shell, remove one cron job) are insufficient.
- Documented remediation guidance states patching the entry-point CVE alone does not remove the infection, since the cron/watchdog/HA-module layers survive patching; full remediation typically requires a rebuild from a clean, verified baseline.

8.4 Relevance to the HVMC IAM Lab Environment

Although the HVMC lab environment (Samba4 AD DC, no FreePBX/Asterisk deployment) is not directly exposed to this specific campaign, the case is instructive for the lab's Identity and Access Management focus: the attack chain's most damaging and hardest-to-remove component is not the initial exploit but the identity layer it creates afterward — 18 backdoor accounts deliberately named to blend into legitimate service-account naming conventions. This reinforces the lab's existing access-control controls (RBAC/DAC via Samba security groups, least-privilege service accounts, and periodic account audits against a known-good baseline) as the practical defense against this class of persistence.

9. Detection & Remediation Recommendations

9.1 Detection

- Hunt for the campaign's static watermark string `trace_e1ebf9066a951be519a24140711839ea` in any PHP files under a FreePBX web root.
- Enumerate immutable files with `lsattr | grep 'i'` across `/var/www/html` and cron-related directories.
- Search crontabs and outbound proxy/firewall logs for connections to 45.95.147.178, 45.234.176.202, and 160.119.69.4.
- Inspect `/root/.bash_profile`, `/root/.bashrc`, and `/etc/rc.local` for injected Base64-encoded stagers.
- Diff `/etc/passwd` and the FreePBX ampusers MySQL table against a known-good baseline for unexpected UID-0 or admin accounts.
- Review Apache/Nginx access logs for requests to `/k.php`, `/z/wr.php`, `/z/wor.php`, and `/z/post/` paths.

9.2 Remediation

- Apply vendor patches for CVE-2025-64328 and CVE-2025-57819 immediately — but treat patching as necessary, not sufficient.
- Rebuild affected FreePBX/Asterisk hosts from a clean, verified baseline rather than attempting in-place cleanup, given the self-healing persistence architecture.
- Remove all identified backdoor OS and MySQL accounts; rotate every FreePBX and service-account credential.
- Restrict outbound connectivity from PBX systems to only required destinations; block the identified C2 ranges at the perimeter.
- Re-enable and enforce SSH hardening (PermitRootLogin no) and confirm firewall rules were not silently reopened.
- Segment VoIP/PBX infrastructure from general-purpose network segments to limit blast radius, consistent with the lab's existing network-segmentation controls.

10. References / Sources

- VirusTotal file report — SHA-256 679515b3d6642a102f3c8bb69c0884912bc700d2a575e2595752e8b446e39c00 (analyzed directly, September 2, 2026).
- Cyble Research & Intelligence Labs, “JOMANGY: INJ3CTOR3's Self-Healing FreePBX Toll Fraud Campaign,” cyble.com/blog/jomangy-inj3ctor3s-self-healing-freepbx-toll-fraud-campaign/
- The Cyber Express, “INJ3CTOR3 Targets FreePBX Systems With JOMANGY Malware,” thecyberexpress.com/inj3ctor3-jomangy-freepbx/
- CybersecurityNews, “Hackers Use Six-Layer Persistence to Maintain Access on Compromised FreePBX Systems,” cybersecuritynews.com/hackers-use-six-layer-persistence/
- GBHackers, “Hackers Use Six-Layer Persistence on FreePBX Systems,” gbhackers.com/persistence-on-freepbx-systems/
- The Hacker News, “900+ Sangoma FreePBX Instances Compromised in Ongoing Web Shell Attacks,” thehackernews.com (Feb 2026).
- ANY.RUN, “JOMANGY: Backdoor Overview,” medium.com/@anyrun/jomangy-backdoor-overview-f8cb32a52949
- MITRE ATT&CK for Enterprise, attack.mitre.org — technique references cited in Section 7.
- Sample originally sourced from MalwareBazaar (abuse.ch): bazaar.abuse.ch/sample/679515b3d6642a102f3c8bb69c0884912bc700d2a575e2595752e8b446e39c00/